Juice Shop, AWS y accesos del grupo.

Archivos y componentes

Estos son los archivos y recursos del proyecto y para qué sirve cada uno.

Archivo o recurso	Tipo	Qué hace
`README.md`	Documentación	Paso a paso de toda la configuración
Instancia EC2 (t3.micro, Ubuntu 26.04)	Servidor	Corre Docker y Juice Shop
Contenedor `juice-shop`	Docker	Juice Shop en el puerto 3000, con reinicio automático
Security Group original	Firewall	SSH (puerto 22) solo desde la IP del administrador
Security Group `juice-portal-access`	Firewall	Reglas TCP 3000 con la IP de cada integrante; lo administra solo el portal
`crear_codigos.py`	Script (en CloudShell)	Genera un código por integrante y guarda solo sus hashes en SSM (Simple System Manager)
`lambda_function.py`	Código de la Lambda	Muestra el login, verifica el código y agrega la IP al Security Group del portal (`juice-portal-access`)
Lambda `juice-portal` y su Function URL	Portal	Página de login con HTTPS
Parámetro SSM `/juice-portal/codes`	Almacén cifrado	Guarda los hashes de los códigos
Política `juice-portal-policy` y rol `juice-portal-role`	IAM	Permisos mínimos de la Lambda
Registro A	DNS	Apunta el subdominio a la IP de la instancia
CloudWatch Logs	Registros	Guarda los intentos y accesos al portal

Pasos del instructivo

Se hicieron los pasos del instructivo de la cátedra: cuenta AWS gratuita con 2FA, alerta de presupuesto de 0 USD, instancia EC2 con Ubuntu Server, conexión por SSH, instalación de Docker y descarga e inicio de Juice Shop. Lo que se agregó o cambió respecto del instructivo está en la sección siguiente.

Decisiones adicionales

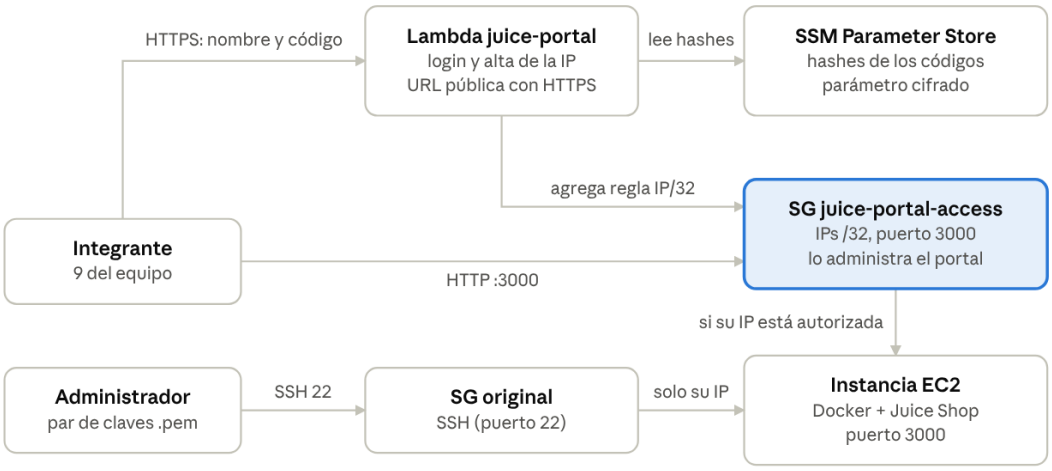
Se sumaron estas decisiones al instructivo para que solo el equipo pueda entrar a Juice Shop aunque las IPs cambien.

Decisión	Qué hace	Qué aporta
Contenedor en segundo plano	`docker run -d --restart unless-stopped`: corre sin terminal y se reinicia solo	No se pierde el progreso si se corta el SSH o se reinicia el servidor.
Puerto 3000 solo para IPs puntuales	Regla TCP 3000 con origen `IP/32`, nunca `0.0.0.0/0`	Limita quién puede entrar.
SSH solo desde la IP del administrador	Regla del puerto 22 con "Mi IP" y par de claves .pem, sin contraseña	Evita escaneos y fuerza bruta contra el acceso de administración.
Subdominio con registro A: `juice.<DOMINIO>:3000`	`juice` tipo A apuntando a la IP pública de la instancia	Se usó un subdominio que teníamos disponible, para evitar entrar con la IP.
Portal de acceso en Lambda: `https://<id>.lambda-url.us-east-1.on.aws`	Función con URL pública HTTPS: login y alta de la IP de origen en el Security Group	Resuelve las IPs cambiantes y agregarlas manualmente, pero sin abrir el puerto a todos (0.0.0.0/0). Corre fuera de la instancia.
Security Group separado para el portal	`juice-portal-access`, asociado a la instancia junto con el original	IAM no limita por puerto: así el portal no puede tocar la regla del SSH.
Política y rol IAM mínimos	Solo puede agregar y borrar reglas de ese grupo, ver las reglas existentes y leer los hashes de cada integrante guardados en SSM. Y no tiene claves propias, usa credenciales temporales.	Mínimo privilegio y ninguna clave de acceso hardcodeada.
Códigos individuales con hash	Los códigos no se guardan: solo se guarda su hash, hecho con scrypt y una sal, en un	Aunque alguien lea el parámetro no obtiene los códigos, y se puede revocar a

Decisión	Qué hace	Qué aporta
	parámetro cifrado de SSM. Los códigos son largos y aleatorios (unos 117 bits) y la verificación tarda siempre lo mismo, para que nadie pueda adivinar fijándose en el tiempo de respuesta.	una sola persona
Control de IPs	Máximo 2 por persona (se borra la más vieja), solo `/32`, sin duplicados.	Limita el tamaño del firewall y el alcance de un código filtrado
Endurecimiento del login	Mismo mensaje ante nombre o código incorrecto, hash falso para nombres inexistentes, espera de 1 s, la página no repite lo que escribe el usuario, cabeceras CSP y `no-store`, la IP sale de `sourceIp`	Evita enumerar nombres, encarece la fuerza bruta, previene XSS y que se falsifique la IP
Registros en CloudWatch	Eventos `LOGIN_FAIL`, `ACCESO_OK` y `GRANT_ERROR`, sin el código	Trazabilidad para revisar

Cómo está armado

El portal autoriza la IP de cada integrante antes de que llegue a Juice Shop



El integrante entra al portal por HTTPS. La Lambda verifica su código contra los hashes de SSM y abre su IP en el grupo del portal, y recién entonces el tráfico a Juice Shop llega a la instancia. El administrador entra por SSH, que pasa por otro grupo.

Limitaciones conocidas

- Juice Shop va por HTTP, sin cifrado, como indica el enunciado.
- El portal es una URL pública: se confía en códigos largos, scrypt y la demora de 1 segundo. No hay bloqueo por intentos ni simultaneidad reservada, porque la cuenta gratis no lo permite.
- Si la red de alguien usa IPv6, el portal no puede autorizarlo. Se carga su IPv4 a mano en el grupo del portal.
- Dos personas detrás de la misma IP (por ejemplo en la facultad) comparten una regla. Si su dueña la pierde por desalojo, la otra tiene que volver a entrar.